

Event Information:

EventID :
161
Event Time :
Jun, 21, 2023, 11:02 AM
Rule :
SOC211 - Utilman.exe Winlogon Exploit Attempt
Level :
Security Analyst
Hostname :
Henry
Ip Address :
172.16.17.149
Process Name :
Utilman.exe
Process Hash :
ded8fd7f36417f66eb6ada10e0c0d7c0022986e9
Parent Process :
Winlogon.exe
Command Line :
net user superman onepunch123 /add
Trigger Reason :
Command Launched from Winlogon
Device Action :
Allowed

Analysis Steps:

Checking the process hash it is cmd.exe.

The screenshot shows the VirusShare file analysis interface. At the top, it indicates the file is 'distributed by Microsoft' with a file hash of 'bc866c0da37e24dc2634dc282c7a0e6f5209da17a8fa105607414c0e7c527'. The file is identified as 'Cmd.Exe' with a size of 272.00 KB and a last analysis date of 14 hours ago. Below this, there are tabs for 'DETECTION', 'DETAILS', 'RELATIONS', 'BEHAVIOR', and 'COMMUNITY'. The 'DETECTION' tab is active, showing a 'Join our Community' banner and a table of security vendors' analysis results.

Security vendors' analysis			Do you want to automate checks?
Acronis (Static ML)	Undetected	AltoLab-V3	Undetected
Alibaba	Undetected	AliCloud	Undetected
ALTac	Undetected	Antiy-AVL	Undetected

Searching for Utilman.exe helped me understand what was going on here and specifically this demonstration by r00tk3r was very helpful:
<https://github.com/r00tk3r/Utilman-Exploit>

Theorised exploitation steps:

The Utilman.exe file is the built-in Windows Utility Manager, which provides Accessibility Tools (like Magnifier or On-Screen Keyboard) directly at the login screen. Because it runs at the login screen before any user has authenticated, it executes with the absolute highest system privileges (NT AUTHORITY\SYSTEM).

The threat actor gained boot-level access to the machine (Henry / 172[.]16.17.149) possibly by booting from a USB or Windows Installation ISO and replaced the legitimate Utilman.exe binary with a copy of cmd.exe.

Once the attacker rebooted the machine back to the normal Windows login screen, they clicked the "Ease of Access" icon. Instead of loading the accessibility menu, Windows blindly executed the swapped file. This opened a Command Prompt window with SYSTEM level privileges.

Operating inside this privileged Command Prompt, the attacker ran: `net user superman onepunch123 /add`. This command successfully created a backdoor local administrator account named superman with the password onepunch123. Because the Device Action is marked as "Allowed", the command was not blocked by endpoint protection, meaning the attacker now has full unauthorised access to the host machine.

Although the exact attack chain cannot be determined the execution behaviour which flagged this alert is highly suspicious and as such it is determined to be of good judgement to consider this alert as a successful True Positive.

Based on following Playbook procedure and the analysis of available information, this alert is determined to be a successful True Positive.

Report:

Incident Summary

Analysis confirms a successful True Positive local privilege escalation and backdoor creation on the host Henry (172[.]16.17.149). A threat actor bypassed authentication by replacing the built-in Windows Utility Manager (Utilman.exe) with the Command Prompt (cmd.exe), subsequently using SYSTEM privileges to add an unauthorised local administrator account.

Incident Details

- **Alert Name:** SOC211 - Utilman.exe Winlogon Exploit Attempt
- **Target Host:** Henry (172[.]16.17.149)
- **Malicious Process:** Utilman.exe (actually cmd.exe) (Hash: ded8fd7f36417f66eb6ada10e0c0d7c0022986e9)
- **Command Line:** net user superman onepunch123 /add
- **Device Action:** Allowed

Analysis and Evidence

- **Binary Swapping:** The process hash for Utilman.exe was verified to be the legitimate Windows Command Prompt (cmd.exe). This indicates the attacker gained boot-level access (likely via an installation ISO or bootable USB) to overwrite the protected system file while the operating system was offline.
- **Privilege Escalation:** The modified Utilman.exe was launched directly by Winlogon.exe via the "Ease of Access" menu at the Windows login screen. Because this process runs prior to user authentication, the substituted Command Prompt was executed with the highest possible NT AUTHORITY\SYSTEM privileges.
- **Backdoor Creation:** Operating within this highly privileged shell, the attacker executed the command net user superman onepunch123 /add. As the device action was logged as "Allowed", a backdoor local account named superman was successfully created, granting the attacker persistent, unauthenticated administrative access.

Actions Taken

1. Analysed process telemetry and confirmed the substitution of Utilman.exe with the Windows Command Prompt.
2. Verified the execution of the net user command, confirming the successful creation of a backdoor user account (superman).
3. Contained the host.
4. Declared the alert a True Positive.
5. Escalated for deletion of the unauthorised superman account, restoration of the legitimate Utilman.exe system file, and an investigation into physical or hypervisor access logs to determine how the attacker mounted the drive to perform the executable swap.

Let's Defend Result

SOC211 - Utilman.exe Winlogon Exploit Attempt

True Positive (+5 Point)

Containment (+5 Point)

Who Performed the Activity? (+5 Point)

What Is Suspicious Activity? (+5 Point)

Determine Suspicious Activity (+5 Point)

Identify the Binary (+5 Point)

What are Living-off-the-land binaries (LOLBins)? (+5 Point)